

SGSI-UNCP

Plantilla de Lista de Chequeo de Auditoría ISO 27001:2022

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Plantilla de Lista de Chequeo de Auditoría ISO 27001:2022
 - 1.1 Cláusulas 4–10 (SGSI)
 - 1.2 Anexo A – Controles Organizacionales (A.5)
 - 1.3 Anexo A – Controles Físicos (A.7)
 - 1.4 Anexo A – Controles Tecnológicos (A.8)

1. Plantilla de Lista de Chequeo de Auditoría ISO 27001:2022

Organización: Universidad Nacional del Centro del Perú (UNCP) **Auditoría ID:** AUD-2026-001 **Auditor:** Mg. Carlos Ramos Quispe **Fecha:** 20/05/2026 **Área/Proceso Auditado:** OTI – Gestión de Activos y Seguridad en Operaciones

Leyenda: C: Cumple | NC: No Conformidad (Mayor/Menor) | OM: Oportunidad de Mejora | N/A: No Aplica

1.1. Cláusulas 4–10 (SGSI)

Requisito	Pregunta de Verificación	Evidencia Objetiva / Hallazgo	Resultado
Cl. 4.1 – Contexto	¿Se han identificado los factores internos y externos (PESTEL/MEFE) en D-SGSI-01?	D-SGSI-01 aprobado con análisis PESTEL, 5 fuerzas Porter, MEFI, MEFE y CAME. Documento archivado y disponible en el sistema documental.	C
Cl. 4.2 – Partes Interesadas	¿Se han identificado las partes interesadas y sus requisitos?	Tabla de 9 partes interesadas (SUNEDU, RENIEC, Minedu, PCM, estudiantes, docentes, administrativos, OTI, proveedores) en D-SGSI-02.	C
Cl. 4.3 – Alcance	¿El alcance del SGSI (D-SGSI-02) está documentado y justificado?	D-SGSI-02 aprobado por CGD; alcance organizacional (sede Huancayo), tecnológico (sistemas misionales), geográfico (local) y temporal (2026–2030).	C
Cl. 4.4 – Procesos	¿Los procesos del SGSI están identificados (D-SGSI-07)?	D-SGSI-07 vigente con matriz de procesos, dependencias y propietarios.	C
Cl. 5.1 – Liderazgo	¿La Alta Dirección demuestra compromiso con el SGSI?	ACT-SGSI-01 firmada; Rector preside CGD mensualmente con agenda de seguridad; presupuesto PGTD-01 de S/ 850,000 asignado.	C
Cl. 5.2 – Política	¿La política del SGSI (D-SGSI-03) está aprobada, comunicada y revisada?	D-SGSI-03 aprobada y publicada en intranet; 48 % del personal entrevistado la conoce (muestra: 140 personas).	OM
Cl. 5.3 – Roles	¿Los roles y responsabilidades del SGSI están definidos y asignados?	Oficial de Seguridad designado por R.S. N.º 023-2026-UNCP; roles documentados en D-SGSI-06 y D-SGSI-07.	C
Cl. 6.1 – Riesgos	¿La evaluación de riesgos sigue la metodología aprobada (D-SGSI-04)?	D-SGSI-04 vigente; R-SGSI-02 completo con 15 riesgos evaluados (5 altos, 10 medios).	C

Requisito	Pregunta de Verificación	Evidencia Objetiva / Hallazgo	Resultado
Cl. 6.1.3 – SoA	¿La SoA (D-SGSI-05) incluye todos los controles y justifica exclusiones?	D-SGSI-05: 84 controles aplicables, 9 excluidos con justificación; cuadro resumen por dominio.	C
Cl. 6.2 – Objetivos	¿Los objetivos de seguridad están definidos y se monitorean (R-SGSI-03)?	R-SGSI-03 con 5 KPIs; pendiente la primera revisión formal de indicadores al corte de mayo 2026.	C
Cl. 7.1 – Recursos	¿La organización ha asignado los recursos necesarios para el SGSI?	Presupuesto 2026: S/ 850,000 (PGTD-01); 3 técnicos OTI asignados al proyecto; consultoría externa contratada.	C
Cl. 7.2 – Competencia	¿El personal es competente en materia de seguridad (P-SGSI-08)?	Programa P-SGSI-08 en ejecución; 85 % del personal OTI certificado en ISO 27001:2022 LA; administrativos: 62 % del módulo básico pendiente.	NC Menor (A.6.3)
Cl. 7.3 – Toma de Conciencia	¿El personal conoce la política y sus responsabilidades?	Solo 48 % de conocimiento en administrativos; campaña de concientización activa desde febrero 2026.	OM
Cl. 7.4 – Comunicación	¿Existen canales definidos para comunicar temas del SGSI?	Intranet, correo institucional, Teams; comunicados del Oficial de Seguridad enviados trimestralmente.	C
Cl. 7.5 – Información Documentada	¿La documentación del SGSI está controlada (P-SGSI-00)?	R-SGSI-00 vigente; documentos en formato .md/.pdf con código único y versión controlada.	C
Cl. 8.1 – Operación	¿Los procesos operativos están planificados y controlados?	Procesos documentados en P-SGSI-02, P-SGSI-03, P-SGSI-04, P-SGSI-05, P-SGSI-06, P-SGSI-07.	C
Cl. 9.1 – Monitoreo	¿Se monitorea y mide el desempeño del SGSI (R-SGSI-03)?	SIEM en implementación; Dashboard de KPIs en desarrollo en Power BI. Monitoreo parcial con herramientas básicas.	OM
Cl. 9.2 – Auditoría Interna	¿Se realizan auditorías internas según el programa (R-SGSI-04)?	Primera auditoría interna en ejecución (AUD-2026-001); programa anual aprobado.	C
Cl. 9.3 – Revisión Dirección	¿La Alta Dirección revisa el SGSI periódicamente?	No se ha realizado la primera Revisión por la Dirección programada para marzo 2026.	NC Menor (Cl. 9.3)
Cl. 10.1 – No Conformidad	¿Las NC se corrigen y se toman acciones correctivas (F-SGSI-04)?	No existe registro formal de acciones correctivas previas a esta auditoría.	NC Menor (Cl. 10.1)
Cl. 10.2 – Mejora Continua	¿Se evidencia mejora continua del SGSI?	Evolución documental del SGSI evidenciada (4 documentos en 2025 a 16+ en 2026); ciclo PHVA parcialmente implementado.	C

1.2. Anexo A – Controles Organizacionales (A.5)

Control	Pregunta de Verificación	Evidencia	Resultado
A.5.1 – Políticas	¿Las políticas de seguridad están documentadas y aprobadas?	POL-SGSI-01 a POL-SGSI-11 publicadas en intranet; firmadas por Rector.	C
A.5.2 – Roles	¿Los roles de seguridad están definidos y asignados?	Roles mapeados en D-SGSI-06 (8 roles SGSI); R.S. N.º 023-2026-UNCP designa Oficial de Seguridad.	C
A.5.10 – Uso Aceptable	¿Se aplica la política de uso aceptable (POL-SGSI-02)?	POL-SGSI-02 publicada; 100 % del personal firma acuerdo en inducción.	C
A.5.15 – Control de Acceso	¿Se utiliza MFA para acceso remoto y sistemas críticos (P-SGSI-03)?	MFA implementado en VPN (Duo Security), correo (Microsoft 365 Authenticator) y ERP ADESA (token SMS).	C
A.5.16 – Identidades	¿La gestión de identidades cubre altas, bajas y cambios?	P-SGSI-03 documentado; integración parcial con AD; gestión de altas/bajas en proceso de automatización.	C
A.5.17 – Autenticación	¿Las contraseñas cumplen con POL-SGSI-06 (NIST SP 800-63B)?	POL-SGSI-06 basada en NIST SP 800-63B; auditoría de cumplimiento: 73 % de cuentas cumplen.	OM
A.5.18 – Derechos de Acceso	¿Se revisan periódicamente los derechos de acceso?	Revisión trimestral de accesos privilegiados; última revisión: abril 2026 (sin hallazgos críticos).	C
A.5.19 – Proveedores	¿Se evalúa la seguridad de los proveedores (POL-SGSI-04)?	POL-SGSI-04 aprobada; P-SGSI-06 documentado; evaluación precontractual de Huawei Cloud completada.	C
A.5.24 – Incidentes	¿Los incidentes se gestionan según el procedimiento (P-SGSI-02)?	P-SGSI-02 vigente; 3 incidentes gestionados en 2026 (1 phishing, 1 caída de servicio, 1 fuga de datos menor).	C
A.5.25 – Continuidad	¿Existe plan de continuidad y se ha probado?	P-SGSI-05 documentado con RTO/RPO; DRP no probado formalmente (pendiente failover testing).	NC Mayor (A.8.16)
A.5.31 – Legal	¿Se cumplen los requisitos legales (Ley 29733, D.L. 1412)?	Política de privacidad en portal web; registro ante ANPDP en proceso; D.S. 016-2024-JUS en revisión.	C

1.3. Anexo A – Controles Físicos (A.7)

Control	Pregunta de Verificación	Evidencia	Resultado
A.7.1 – Perímetros	¿El Datacenter y áreas críticas tienen perímetros de seguridad definidos (POL-SGSI-07)?	POL-SGSI-07 vigente; perímetros definidos: Data Center (piso 3), sala de servidores FIIS, sala de comunicaciones DGA.	C
A.7.2 – Acceso Físico	¿El acceso a áreas seguras está controlado (biométrico + tarjeta)?	Data Center: biométrico (huella dactilar) + tarjeta RFID; sala FIIS: solo biométrico; registro de visitas en físico.	C

Control	Pregunta de Verificación	Evidencia	Resultado
A.7.7 – Escritorio Limpio	¿Se aplica la política de escritorio y pantalla limpios (POL-SGSI-02)?	POL-SGSI-02 incluye escritorio limpio; auditoría visual: 15 % de escritorios con documentos visibles al cierre.	OM
A.7.9 – Activos Fuera	¿Los activos fuera de las instalaciones están protegidos?	Política de dispositivos móviles (POL-SGSI-05) vigente; 2 laptops de docentes extraviadas sin reporte de cifrado.	NC Mayor (A.7.9)
A.7.14 – Eliminación Segura	¿Los activos se eliminan según P-SGSI-07 (NIST SP 800-88)?	P-SGSI-07 documentado; no se han ejecutado eliminaciones desde su aprobación (sin activos en baja durante 2026).	N/A

1.4. Anexo A – Controles Tecnológicos (A.8)

Control	Pregunta de Verificación	Evidencia	Resultado
A.8.1 – Dispositivos Móviles	¿Los dispositivos móviles cumplen con POL-SGSI-05?	POL-SGSI-05 publicada; 78 % de dispositivos móviles con MDM (Microsoft Intune) desplegado; 22 % pendiente.	C
A.8.3 – Contraseñas	¿Se usan gestores de contraseñas empresariales y MFA (POL-SGSI-06)?	Gestor de contraseñas Bitwarden Enterprise implementado para OTI; MFA activo en servicios críticos.	C
A.8.8 – Antimalware	¿Todos los endpoints tienen protección antimalware actualizada?	Microsoft Defender for Endpoint desplegado en 340 equipos; última actualización de firmas: 19/05/2026.	C
A.8.10 – Eliminación Info.	¿La información se elimina de forma segura al finalizar su ciclo de vida?	P-SGSI-07 aprobado; Cryptographic Erase solo en SSD que lo soportan; HDD pendientes de desmagnetización.	C
A.8.13 – Respallos	¿Los respaldos se realizan según POL-SGSI-03 y se prueban trimestralmente?	POL-SGSI-03 vigente; backups diarios a Huawei Cloud CBR; última prueba de restauración: febrero 2026 (exitosa).	C
A.8.16 – Monitoreo	¿Se monitorean los eventos de seguridad (logs, SIEM)?	SIEM (Wazuh) en implementación; logs de Huawei Cloud CBR sin revisión desde enero 2026.	NC Mayor (A.8.16)
A.8.25 – Desarrollo Seguro	¿El desarrollo de software sigue POL-SGSI-01 (SAST/DAST/SBOM)?	POL-SGSI-01 vigente; SAST (SonarQube) implementado en 2 proyectos; DAST pendiente; SBOM no generado.	OM
A.8.32 – Gestión Cambios	¿Los cambios en TI siguen el procedimiento P-SGSI-04 (CAB)?	P-SGSI-04 vigente; 5 cambios registrados en 2026; 4 con acta CAB, 1 emergente sin acta documentada.	C

Notas del Auditor:

Se verificaron 40 controles de la lista de chequeo durante la auditoría del 20 al 22 de mayo de 2026 en las instalaciones de la UNCP (Av. Mariscal Castilla N.º 3909, El Tambo, Huancayo). Se encontraron 2 NC mayores (A.7.9 y A.8.16) y 2 NC menores (Cl. 9.3 y Cl. 10.1), además de 3 OM y 1 N/A. Se recomienda priorizar la implementación del monitoreo continuo y el cifrado de dispositivos móviles.